Meituan Stock-Sync

Detection-Resilience & Operational-Security Report

How the automated inventory sync for the Roots Meituan merchant stores is kept stable against Meituan ’s risk-control (anti-bot) systems — controls in place, residual risks, and the recommended durable path.

Scope	Roots-owned Meituan merchant stores: 天河 (Tianhe), 越秀 (Yuexiu)
System	roots-v2 meituan-sync daemon (Playwright browser automation)
Status	Tianhe LIVE; Yuexiu pending one-time login
Date	2026-06-24
Classification	Internal / operational

1. Purpose & scope

This document describes the measures that keep Roots ’ own Meituan inventory-sync automation from being flagged by Meituan ’s automated risk-control. The automation logs into Roots ’ own merchant accounts and mirrors stock levels so the Meituan storefront does not oversell while the same products sell on other channels. It does not touch other merchants, customers, payments, or Meituan ’s infrastructure beyond the normal merchant portal.

“ Detection resilience ” here means avoiding operational disruption — when Meituan ’s anti-bot flags the session it serves a 验证中心 (verification-centre) human captcha and invalidates the login, which stalls stock sync until a human re-authenticates. The goal of every control below is to keep the merchant ’s own session trusted and stable, not to conceal any wrongdoing.

ToS note & durable path. Browser automation of the merchant portal is contrary to Meituan ’s terms; the officially sanctioned, detection-proof route is Meituan ’s Open API (开放平台). That remains the recommended long-term solution (section 8). The controls here reduce friction for the interim browser-based approach.

2. Threat model

What is being detected, by whom, and what happens on detection.

Element	Detail
Adversary	Meituan automated risk-control (not a human investigator). Goal is to stop account-takeover, fraud, and competitor scraping.
Asset	A trusted, logged-in merchant session per store.
Detection → effect	Session flagged → 验证中心 captcha on every navigation → sync stalls until a human passes it and re-logs-in.
Consequence class	Operational (downtime / manual toil). Not fraud, not third-party harm, not legal jeopardy — it is the merchant ’s own store.
Risk level	Low and self-contained: even if noticed, the activity is benign self-service inventory upkeep.

3. Architecture overview

- Runtime: a Node/Playwright daemon (meituan-sync, pm2-managed) on the Hong Kong production box, one long-lived Chromium browser per store.
- Egress IP: all traffic is routed through a Guangzhou datacentre proxy (Aliyun SWAS, tinyproxy :8888) so the merchant appears to connect from the store's own city instead of a Hong Kong datacentre — the single biggest historical trigger of the captcha.
- Writes: stock is set through Meituan's own JSON API (batchUpdateSkuStock), issued by the logged-in browser's own fetch — so it carries real Chrome TLS, header order and cookies, not a Node HTTP client's fingerprint.
- Reads: order polling and stock reads use the same authenticated session and content iframe the merchant UI uses.

3.1 Planned egress upgrade — Guangzhou local IP

The current egress is a Guangzhou datacentre proxy (tagged 阿里云). It is sufficient today, but a real Guangzhou local IP is cleaner still — a residential / consumer line is the least likely of all to be challenged. Two routes are planned, in preference order:

Option	What	Trade-off
A. Store's own broadband (preferred)	A small always-on device at the 天河 store opens a reverse tunnel (frp / ssh -R) out to the HK box; daemon egress exits the store's real Guangzhou line. Survives carrier NAT (CGNAT) — the device dials out, nothing connects in.	Most authentic IP possible (literal merchant premises); ~free. Depends on store power / internet uptime; needs one device + auto-reconnect.
B. Guangzhou residential / 家宽 proxy	A Guangzhou home-broadband (ADSL / 拨号) VPS from a marketplace vendor, used as a root server (reuse the SSH tunnel) or an HTTP/SOCKS5 endpoint dropped straight into MEITUAN_PROXY_URL.	Plug-and-play; ~ ¥ 100 – 250/mo. Quality varies by vendor — must be verified (below) before trusting.

Procurement & verification rules (learned the hard way — one vendor's "Guangzhou" line geolocated elsewhere):

- Verify before paying / switching: confirm the exit IP geolocates to Guangzhou (ip138 / Taobao IP lookup) — not Shenzhen, not another city, not a datacentre tag.
- Stable for the session: the IP must hold unchanged for the whole login (~15 min); it may only change on a manual redial, never auto-rotate mid-session.
- Same IP for birth & run: mint the session and run the daemon through the same IP, so the login's origin and the daemon's origin match.
- Cut-over is config-only: point MEITUAN_PROXY_URL at the new endpoint and restart — no code change; the datacentre proxy stays as fallback.

4. Detection vectors & mitigations

Vector	Why it flags	Mitigation in place
IP reputation	A Guangdong merchant connecting from a HK datacentre IP is incoherent.	Guangzhou proxy egress; session born & run on the same IP. (Strongest fix.)
Automation flags	navigator.webdriver / AutomationControlled = obvious bot.	Launch flag + init-script remove the tell.
Browser fingerprint	Headless & Linux surfaces contradict a Windows UA.	Coherent Windows identity; headful under Xvfb; plugin/permission fills; Windows fonts.
TLS / client	Node HTTP client TLS != Chrome.	Writes use the browser ' s own fetch (real Chrome stack).
Behaviour / timing	Robotic cadence, 3am edits, hammering after errors.	Jitter, store-hours gating, warm-up nav, verify cool-down, slow polling.
Session churn	Frequent fresh logins each invite a challenge.	Long-lived session, periodic re-persist to survive crashes.

5. Implemented controls (detail)

IP Guangzhou proxy egress (Tier 4)

All daemon traffic exits via a Guangzhou datacentre proxy (8.163.120.72:8888, HK-source-locked). A fresh login through this IP reaches a clean dashboard with no 验证中心 — confirming the earlier challenges were an IP/flagged-session problem, not fingerprint. Per-store override via env; unset = direct.

FP Webdriver hiding (Tier 1)

--disable-blink-features=AutomationControlled plus an init-script forcing navigator.webdriver = undefined — removes the single strongest bot signal.

FP Coherent Windows identity (Tier 2)

A single consistent Windows-desktop Chrome story across UA, platform, vendor, languages, hardwareConcurrency / deviceMemory, client-hints (userAgentData + high-entropy), window.chrome.runtime, and a spoofed WebGL vendor/renderer (hides the headless SwiftShader string). Context locale zh-CN, timezone Asia/Shanghai. Internal consistency is the rule — a contradictory spoof is louder than none.

FP Headful under Xvfb (Tier 3)

The daemon now runs Chromium headful on a virtual display (Xvfb :99) instead of headless, shedding headless-only tells the init-script cannot cover. Opt-in via MEITUAN_HEADFUL=1 + DISPLAY; falls back to headless (never crashes) if the display is absent.

FP Headless-fallback fills

For the rare headless-fallback path: synthesize navigator.plugins / mimeTypes (PDF-viewer entries) only when empty, and align navigator.permissions.query to the real Notification.permission — closing the classic headless mismatches. No-op under headful.

FP Windows fonts on host

The Linux host now carries the Microsoft core fonts (Arial, Times, Verdana …) + Liberation metrics so font enumeration matches the claimed Windows UA instead of leaking a Linux font set.

BEH Behavioural timing

All actions fire on jittered, randomised gaps (never a fixed cadence); the two stores are staggered, never lockstep. Order polling is deliberately slow (~5 min ±40%) to minimise recurring page loads.

BEH Store-hours write gating

Stock pushes are suppressed while a store is closed on Meituan — a backend edit at 3am is a bot tell, and accuracy does not matter until reopen. Rows queue and flush at open.

BEH Warm-up navigation

Before a stock-write burst the session navigates to the inventory list (where a human edits stock) so the write API issues from the product page, not from the orders screen left over from the last poll.

BEH Verification cool-down

On a 验证中心 hit the store is parked with an escalating back-off (30 min → ×2 → cap 4 h); the daemon stops re-poking the verify page (which only deepens the flag / poisons the IP) and resumes on the next clean poll.

SES Session longevity

One long-lived session per store; the on-disk session is re-persisted on a 30-min throttle while logged in, so a crash restores recent (rotated) cookies instead of forcing a fresh login — the riskiest event. A logged-out shell can no longer overwrite a good session file.

6. Residual risks

Risk	Likelihood / impact	Note
Datacentre IP still tagged 阿里云	Low / med	A Guangzhou residential or store-broadband IP would be cleaner; currently sufficient.
Proxy single point of failure	Med / high	If the GZ proxy is down, sync breaks. No automatic failover today.
Segoe UI font absent	Low / low	Core fonts installed; Segoe UI (proprietary) not. Weak signal.
Two stores share one fingerprint	Low / low	Tianhe & Yuexiu identities are byte-identical; per-store variation deferred.
Browser crash / memory pressure	Med / med	Crash-recovery + session re-persist mitigate; root cause is 2 Chromiums on a small box.
ToS exposure (inherent)	—	Browser automation is against ToS regardless of stealth. Open API removes this entirely.

7. Operational dependencies & runbook

Things that must stay up for the controls to hold:

- pm2 xvfb process (Xvfb :99) — if it dies or DISPLAY is unset, the daemon silently falls back to headless (look for the “no DISPLAY” warning).
- Guangzhou proxy (MEITUAN_PROXY_URL) — egress IP; if down, sync breaks.
- Persisted sessions in data/meituan-sessions/ — restored on start.

Deploy (daemon is not redeployed by the normal CI):

- scp the changed lib/scripts file(s) to the box, then pm2 restart meituan-sync.
- Verify each file landed (grep for a new symbol) before restarting.

Re-login a store (human, on 验证中心 or session loss):

- Bring up the GZ tunnel, run the headed login helper, complete SMS + slider, copy the session up, restart the daemon.
- A human must pass the captcha / enter the SMS code — this step is intentionally manual.

8. Recommendation

The browser-based controls above are now comprehensive and the live store (Tianhe) runs clean. For a durable, ToS-compliant end state, migrate stock sync to Meituan’s Open API (开放平台, waimaiopen.meituan.com): it uses signed server-to-server calls with no login session and no browser, so there is no fingerprint or captcha surface at all. The browser path remains a capable fallback and the route for anything the API does not expose.

Priority order if pursued further: (1) keep the Open-API migration on the roadmap; (2) add proxy failover / health alerting; (3) consider a Guangzhou residential or store-broadband egress; (4) per-store fingerprint variation.

Prepared as internal operational documentation for the Roots / roots-v2 platform. Reflects the state of the meituan-sync daemon on 2026-06-24 (branch guanyi-stock-sync).